



中国互联网安全大会



360互联网安全中心

ISC
2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

智能移动终端攻防论坛



中国互联网安全大会



360互联网安全中心

一根数据线引发的 安卓高危漏洞

周亚金

360无线安全研究院高级研究员

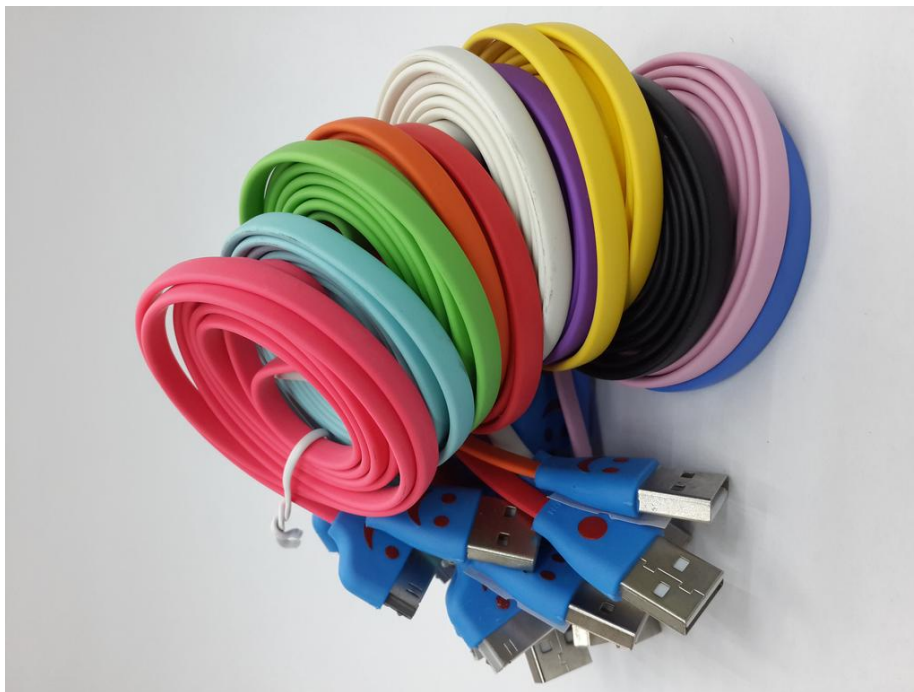
<http://yajin.org>

关于我

- 北卡州立大学获得博士学位
- 论文发表在多个国际知名安全会议
- 无线安全研究院高级研究员
- 360加固保技术负责人

邪恶女佣





数据线连接电脑

- 充电
- 备份照片
- 传输文件
- 刷机，安装应用
- 开发调试应用



潜在的威胁？

JDWPExposed

- 影响安卓**所有**版本，谷歌确认为高危漏洞
- 通过数据线连接电脑USB接口来利用

Comment #1 on issue 182294 by jlari...@google.com: unsafe exposure of the JDWP interface through app_process

<https://code.google.com/p/android/issues/detail?id=182294>

Thanks for the report and detailed reproduction information!

It seems like the problem is that gJdwpAllowed is set to True by default in art/runtime/debugger.cc and will only get set to False if the process is launched with Zygote. If the process doesn't require Zygote, like the command-line tools (am, pm, etc), the debugger is still enabled.

For now we're rating this as a **HIGH** severity vulnerability, but that might change as we spend more time analyzing the bug.

Project Member #5 memil...@google.com

Aug 20, 2015

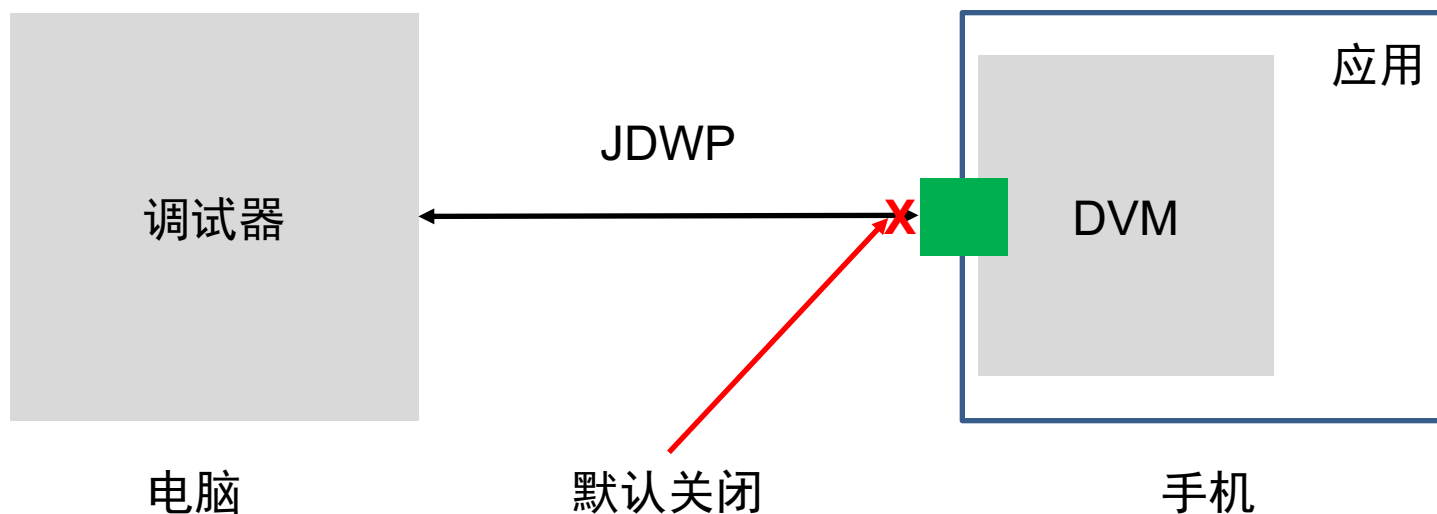
Congratulations! The rewards panel decided to reward you USD\$1,500 for reporting this **high severity vulnerability** and including a proof-of-concept!

JDWPExposed

- 2015/08/08: 报告谷歌
- 2015/08/13: 谷歌确认为高危漏洞，确定 CVE编号 (CVE-2015-3865)
- 2015/08/20: \$1500的奖励
- 2015/09/15: 谷歌推送补丁给合作伙伴，AOSP预计下月更新

JDWP

- Java Debug Wire Protocol
- 安卓系统原生支持
- 默认关闭，开发者显式打开



JDWPExposed

- JDWP接口在特定内置系统功能被调用时默认打开
- 影响的设备：所有安卓设备
- 可能的危害：提权, 窃取隐私数据, ...

漏洞利用场景

- 恶意程序感染用户电脑
- 用户手机通过数据线连接电脑
- 攻击者利用漏洞提权，执行恶意代码

演示1: 破解用户的手机屏幕锁



演示2: 窃取微信聊天记录

解密微信数据库

- 加密的sqlite3数据库
- 秘钥: md5(IMEI|UIN)[0:7]
- UIN获取

```
<?xml version='1.0' encoding='utf-8' standalone='yes' ?> <map>  
    <string name= "last_login_uin" >106836xxxx</string>  
</map>
```

安全建议

- 手机厂商：应用谷歌补丁，推送OTA
- 应用开发者：避免使用能触发漏洞的命令，实时检测应用状态(是否被attach)
- 用户：升级手机系统，避免连接到不可信电脑，清除adb授权

然而...

安卓系统生态圈

- Google：安卓系统碎片化
- 安卓手机厂商：引入新的安全问题
- 应用开发者：安全知识缺乏
- 用户：缺乏安全意识

加固保,守护天下开发者!

<http://jiagu.360.cn>

<http://yajin.org>

Q&A